Uniwersytet Warmińsko-Mazurski w Olsztynie
Wydział Matematyki i Informatyki

Zarządzanie Projektem Informatycznym

Sprawozdanie

Laboratorium nr 7

Aplikacja webowa do szyfrowanych notatek

Poziomy gotowości technologicznej TRL 1–5, grupa docelowa i komercjalizacja

Zespół: Wiktor Dąbrowski / Krystian Czajkowski
Kierownik projektu: demokracja
Prowadzący: mgr inż. Artur Samojluk
Data: 28.10.2026

Spis treści

1. Poziom TRL 1 – badania podstawowe 3
1.1. Opis idei 3
1.2. Potencjalne zastosowania 3
1.3. Zagadnienia do rozstrzygnięcia 3
2. Poziom TRL 2 – badania przemysłowe 3
2.1. Koncepcja technologii i jej przyszłego zastosowania 3
2.2. Lista rzeczy potrzebnych do dalszego rozwoju projektu 3
3. Poziom TRL 3 – badania przemysłowe 4
3.1. Zakres prac badawczych 4
4. Poziom TRL 4 – badania przemysłowe 4
4.1. Weryfikacja koncepcji w warunkach laboratoryjnych 4
4.2. Ryzyka i sposoby ich eliminacji 6
5. Poziom TRL 5 – badania przemysłowe 6
5.1. Weryfikacja koncepcji w środowisku zbliżonym do rzeczywistego 6
6. Grupa docelowa i komercjalizacja 7
6.1. Grupa docelowa 7
6.2. Model biznesowy 7
6.3. Szacowana wielkość rynku 8
7. Skład zespołu i role 8

1. Poziom TRL 1 – badania podstawowe

1.1. Opis idei

W wyniku analiz informatycznych zespół opracował koncepcję **aplikacji webowej do przechowywania notatek**, w której treść jest **szyfrowana po stronie użytkownika**, zanim opuści przeglądarkę. Serwer przechowuje wyłącznie zaszyfrowane dane i nie ma technicznej możliwości ich odczytania, nawet w razie włamania do bazy lub dostępu administratora (model *zero-knowledge*).

Wstępne obserwacje wskazują, że współczesne przeglądarki udostępniają mechanizmy kryptograficzne (*Web Crypto API*) umożliwiające szyfrowanie standardowymi algorytmami (np. *AES-GCM*) bez instalowania dodatkowego oprogramowania. Klucz szyfrujący może być wyprowadzany z hasła użytkownika funkcją do tego przeznaczoną (np. *PBKDF2* lub *Argon2*), dzięki czemu hasło nie jest przesyłane na serwer w postaci jawnej.

1.2. Potencjalne zastosowania

Na tym etapie nie było jeszcze określone, jaki konkretny produkt powstanie. Zidentyfikowano następujące potencjalne zastosowania:

- osobisty notatnik dla osób dbających o prywatność,
- bezpieczne przechowywanie danych wrażliwych (hasła, dane medyczne, dokumentacja),
- narzędzie dla małych zespołów lub organizacji bez własnej infrastruktury bezpieczeństwa,
- współdzielone notatki szyfrowane end-to-end.

1.3. Zagadnienia do rozstrzygnięcia

- sposób odzyskiwania dostępu po utracie hasła (przy modelu zero-knowledge **brak hasła oznacza utratę danych**),
- możliwość wyszukiwania w zaszyfrowanych notatkach,
- bezpieczne udostępnianie notatek innym użytkownikom.

2. Poziom TRL 2 – badania przemysłowe

2.1. Koncepcja technologii i jej przyszłego zastosowania

Przeprowadzono wstępną analizę możliwych zastosowań technologii szyfrowania notatek po stronie klienta. Ustalono, że optymalnym rozwiązaniem jest **aplikacja webowa** dostępna w nowoczesnych przeglądarkach na komputerach i urządzeniach mobilnych, dzięki czemu nie ma potrzeby tworzenia osobnych wersji na poszczególne systemy operacyjne (Windows, Linux, Android, iOS).

Aplikacja będzie składać się z dwóch części: **interfejsu działającego w przeglądarce**, który odpowiada za szyfrowanie i odszyfrowywanie notatek, oraz **serwera z API i bazą danych**, który przechowuje wyłącznie dane zaszyfrowane. Interfejs powinien być prosty i intuicyjny, zgodnie z zasadą: *im mniej kroków do rezultatu, tym lepiej*. Utworzenie, zapisanie i odczytanie notatki powinno wymagać możliwie najmniejszej liczby kliknięć, a szyfrowanie ma działać w sposób niewidoczny dla użytkownika po jednorazowym podaniu hasła.

Jako główny kierunek rozwoju przyjęto **osobisty notatnik dla użytkowników ceniących prywatność**, z możliwością rozbudowy o bezpieczne przechowywanie danych wrażliwych. Opcja uruchamiania własnej instancji aplikacji w kontenerach *Docker* zostanie rozważona jako jeden z wariantów wdrożenia dla małych zespołów.

2.2. Lista rzeczy potrzebnych do dalszego rozwoju projektu

- środowisko do testów (kontenery Docker Compose odwzorowujące środowisko produkcyjne),

- 2x stanowisko programistyczne z nowoczesnym środowiskiem programistycznym (np. VS Code lub PyCharm),
- repozytorium kodu Git z automatyczną integracją i testami (CI),
- serwer (VPS) z dostępem do Internetu, własną domeną i certyfikatem TLS (HTTPS),
- baza danych PostgreSQL,
- biblioteki kryptograficzne (Web Crypto API, implementacja Argon2) wraz z dokumentacją standardów,
- narzędzia do testów bezpieczeństwa (np. OWASP ZAP) oraz konsultacja lub przegląd rozwiązań kryptograficznych,
- urządzenia i przeglądarki testowe (desktop i mobilne),
- narzędzie do zarządzania zadaniami w zespole (np. Trello lub Jira).

3. Poziom TRL 3 – badania przemysłowe

3.1. Zakres prac badawczych

W ramach realizacji III poziomu gotowości technologicznej zostaną zrealizowane prace badawcze, których celem jest **potwierdzenie założeń koncepcji**. Poszczególne moduły będą badane osobno, bez łączenia ich w całość, w następującym zakresie:

- **Moduł szyfrowania i odszyfrowywania w przeglądarce** – szyfrowanie notatek algorytmem AES-GCM z wykorzystaniem Web Crypto API. Szczególny nacisk zostanie położony na poprawność danych po odszyfrowaniu. Moduł zostanie wyposażony w mechanizm porównywania odszyfrowanej treści z oryginałem, a miarą końcową będzie *współczynnik zgodności* wyrażony w procentach. Zbadany zostanie również wpływ wielkości notatki na czas szyfrowania i odszyfrowywania.
- **Moduł wyprowadzania klucza z hasła** – wyprowadzanie klucza szyfrującego funkcją Argon2 lub PBKDF2. Badania skupią się na znalezieniu optymalnego punktu parametrów funkcji: czas wyprowadzania klucza na typowych urządzeniach (w tym mobilnych) ma być akceptowalny dla użytkownika, a jednocześnie wystarczająco kosztowny dla potencjalnego atakującego.
- **Moduł przechowywania zaszyfrowanych danych** – serwer z API i bazą PostgreSQL przyjmujący i udostępniający wyłącznie dane zaszyfrowane. Zostanie zweryfikowane, że w bazie danych nie występuje żadna treść notatek w postaci jawnej, oraz zbadana wydajność zapisu i odczytu w zależności od liczby i wielkości notatek.
- **Moduł uwierzytelniania** – logowanie użytkownika bez przesyłania hasła w postaci jawnej na serwer. Zostanie sprawdzona możliwość rozdzielenia danych służących do uwierzytelnienia od materiału służącego do wyprowadzenia klucza szyfrującego.

Na poziomie wskazanego etapu zostanie również opracowany **model analityczny odporności na atak siłowy** (*brute force*), wyrażający czas potrzebny na odgadnięcie hasła w zależności od jego długości oraz parametrów funkcji wyprowadzania klucza. Posłuży on do doboru parametrów bezpieczeństwa aplikacji.

4. Poziom TRL 4 – badania przemysłowe

4.1. Weryfikacja koncepcji w warunkach laboratoryjnych

W ramach realizacji IV poziomu gotowości technologicznej zostaną zrealizowane prace badawcze, w których **zintegrowane moduły prototypu** będą testowane w warunkach laboratoryjnych, w następującym zakresie:

- **Moduł szyfrowania i odszyfrowywania** – przygotowano zestaw kontrolny 100 notatek o zróżnicowanej długości (od kilku znaków do kilkuset kilobajtów), w tym zawierających polskie znaki diakrytyczne i znaki specjalne. Wykonano 100 serii testów cyklu szyfrowanie – odszyfrowanie, a odszyfrowaną treść porównano z oryginałem. Algorytm wykazał odchylenia w niektórych seriach, w których notatki zawierały znaki spoza podstawowego zestawu. Ustalono, że na wynik ma wpływ sposób kodowania znaków przed szyfrowaniem. Wprowadzono poprawkę (jawne kodowanie UTF-8) i ponownie wykonano 100 serii testów. Wyniki w całej serii były zgodne z oryginałem, a odchylenia zostały wyeliminowane.
- **Moduł wyprowadzania klucza z hasła** – wykonano 100 serii pomiarów czasu wyprowadzania klucza dla kilku zestawów parametrów funkcji na różnych urządzeniach (komputer stacjonarny, laptop, telefon). Zebrane dane posłużyły do sporządzenia wykresów zależności czasu od parametrów. Ustalono, że czas na urządzeniach mobilnych jest wielokrotnie dłuższy niż na komputerze, w związku z czym wybrano parametry stanowiące kompromis pomiędzy komfortem użytkownika a odpornością na atak siłowy, zgodnie z modelem opracowanym na poziomie TRL 3.
- **Moduł przechowywania zaszyfrowanych danych** – przesłano przez API do bazy 100 zaszyfrowanych notatek, a następnie przeszukano zawartość bazy danych pod kątem fraz z oryginalnych notatek. W bazie nie stwierdzono treści w postaci jawnej. Wykazano natomiast, że w trybie debugowania logi aplikacji mogą zawierać fragmenty przesyłanych danych. Zmieniono konfigurację logowania i ponownie wykonano test, a wyniki nie wykazały już żadnych jawnych danych. Zmierzono także czas zapisu i odczytu w zależności od liczby i wielkości notatek.
- **Moduł uwierzytelniania** – wykonano 100 serii logowania z poprawnymi i błędnymi hasłami, a ruch sieciowy zbadano pod kątem obecności hasła w postaci jawnej. Hasła w ruchu nie stwierdzono. Zauważono niewielką różnicę czasu odpowiedzi serwera dla poprawnych i niepoprawnych danych, która mogłaby ułatwić atak. Wprowadzono porównywanie danych w stałym czasie i powtórzono testy, a różnice zostały zminimalizowane.
- **Test zintegrowany** – wykonano 100 serii pełnego cyklu: podanie hasła, wyprowadzenie klucza, szyfrowanie notatki, wysłanie na serwer, pobranie, odszyfrowanie. Miarą końcową był *współczynnik zgodności* odszyfrowanej treści z oryginałem wyrażony w procentach.

4.2. Ryzyka i sposoby ich eliminacji

Ryzyka uporządkowano według szacowanego prawdopodobieństwa wystąpienia. **Ryzyka o najwyższym wskaźniku procentowym są eliminowane w pierwszej kolejności.**

Ryzyko	Szansa wystąpienia	Rozwiązanie
Zbyt długi czas wyprowadzania klucza na słabszych urządzeniach, skutkujący wolnym logowaniem.	40%	Rozszerzenie testów o różne klasy urządzeń (w tym starsze telefony) i dobór parametrów funkcji jako kompromisu pomiędzy czasem a bezpieczeństwem.
Niekompatybilność danych pomiędzy modułami (kodowanie znaków, format szyfrogramu, sól i wektor inicjujący), uniemożliwiająca odszyfrowanie notatki.	30%	Zdefiniowanie jednego, jednoznacznego formatu paczki z szyfrogramem oraz zaprogramowanie automatycznych testów integracyjnych z użyciem polskich znaków i znaków specjalnych.
Różnice w działaniu Web Crypto API w różnych przeglądarkach.	25%	Rozszerzenie testów o przeglądarki desktopowe i mobilne (Chrome, Firefox, Safari) oraz wydzielenie warstwy abstrakcji nad operacjami kryptograficznymi.
Wyciek danych w postaci jawnej na serwerze przez logi lub metadane.	20%	Przegląd konfiguracji logowania, wyłączenie zapisu treści żądań oraz testy automatyczne przeszukujące bazę i logi pod kątem jawnych danych.

5. Poziom TRL 5 – badania przemysłowe

5.1. Weryfikacja koncepcji w środowisku zbliżonym do rzeczywistego

W celu połączenia zaprogramowanych komponentów zostanie zastosowany **wzorzec architektoniczny MVC** (*Model-View-Controller*, pol. Model-Widok-Kontroler). Zaprogramowany zostanie dodatkowy **moduł Kontrolera** działający po stronie przeglądarki, którego zadaniem będzie koordynacja pracy aplikacji: przyjmowanie danych od użytkownika, przekazywanie ich do właściwych modułów oraz odświeżanie widoku.

Prace zostaną przeprowadzone w **środowisku zbliżonym do rzeczywistego**. Aplikacja zostanie uruchomiona w kontenerach Docker Compose odwzorowujących środowisko produkcyjne (połączenie HTTPS, baza PostgreSQL), a interfejs będzie testowany w przeglądarkach desktopowych i mobilnych. Zgodnie z zasadą zbliżania warunków do rzeczywistych **zwiększono liczbę testów** względem poprzedniego poziomu do 1000 notatek w zestawie kontrolnym.

- **Kontroler** – zostanie zaprogramowany w celu koordynowania pracy pozostałych modułów. Przeprowadzone zostaną testy jego stabilności (wielokrotne uruchamianie i zamykanie sesji użytkownika); błędy destabilizujące pracę kontrolera będą korygowane do momentu wykonania cyklu bez błędów. Zweryfikowane zostanie, czy kontroler prawidłowo odbiera dane, dokonuje ich podstawowej identyfikacji i przekazuje je do właściwych modułów. W kontrolerze zostaną zdefiniowane połączenia (wtyczki) do modułów szyfrowania, wyprowadzania klucza, komunikacji z serwerem i uwierzytelniania oraz podstawowa weryfikacja typów danych kierowanych do każdego z nich. Sprawdzona zostanie reakcja na dane celowo uszkodzone (zmodyfikowany szyfrogram, uszkodzony format paczki, błędny typ pola, zbyt długa notatka). W

przypadku niewłaściwej reakcji zostanie przeprowadzona analiza przyczyny i wprowadzone zmiany w warunkach weryfikujących zgodność danych. Pomyślny test (uzyskanie zwrotnej informacji o błędzie bez zawieszenia aplikacji) pozwoli na integrację z pozostałymi modułami.

- **Moduł szyfrowania i odszyfrowywania** – dokonano integracji z kontrolerem. Przetestowano działanie samego modułu oraz w relacji z kontrolerem na próbnej bazie 1000 notatek (w tym z polskimi znakami i o zróżnicowanej długości) w zakresie poprawności szyfrowania, odszyfrowywania i kompletności danych. Sprawdzono również, czy zmodyfikowany szyfrogram zostaje odrzucony dzięki kontroli integralności AES-GCM. Ewentualne błędy zostaną usunięte poprzez poprawki programistyczne i ponowne testy na tych samych danych.
- **Moduł wyprowadzania klucza z hasła** – dokonano integracji z kontrolerem. Zweryfikowano, że hasło jest przekazywane wyłącznie do tego modułu i nie jest wysyłane dalej, oraz zmierzono czas wyprowadzania klucza podczas pracy pełnej aplikacji, w szczególności na urządzeniach mobilnych. Sprawdzono reakcję systemu na błędne hasło (nieudane odszyfrowanie i czytelny komunikat dla użytkownika).
- **Moduł przechowywania zaszyfrowanych danych** – dokonano integracji z kontrolerem poprzez API. Zapisano i pobrano 1000 notatek, sprawdzając, czy szyfrogram po pobraniu jest identyczny z wysłanym. Przeprowadzono test jednoczesnego dostępu około 50 symulowanych użytkowników. W przypadku błędów spowodowanych przeciążeniem serwera lub bazy zostaną one usunięte poprzez analizę wyników i korektę konfiguracji, a następnie test zostanie powtórzony.
- **Moduł uwierzytelniania** – dokonano integracji z kontrolerem. Przetestowano rejestrację, logowanie, wylogowanie i wygaśnięcie sesji oraz sprawdzono, czy po wylogowaniu klucz szyfrujący zostaje usunięty z pamięci przeglądarki.
- **Widok (interfejs użytkownika)** – zweryfikowano podstawowe scenariusze (utworzenie, edycja, odczyt i usunięcie notatki) w przeglądarkach desktopowych i mobilnych, jakość komunikacji widoku z kontrolerem oraz zgodność z zasadą minimalnej liczby kliknięć.
- **Test zintegrowany** – wykonano 1000 pełnych cykli (hasło, wyprowadzenie klucza, szyfrowanie, zapis na serwerze, pobranie, odszyfrowanie). Pierwsze uruchomienie wykazało błędy komunikacji pomiędzy kontrolerem a modułem przechowywania wynikające z niezgodności formatu przesyłanych danych. Po analizie wprowadzono korektę i ponownie wykonano test na tych samych 1000 notatkach, uzyskując pełną zgodność odszyfrowanej treści z oryginałem.

6. Grupa docelowa i komercjalizacja

6.1. Grupa docelowa

W skład grupy docelowej wchodzą dwa segmenty. Pierwszy to **użytkownicy indywidualni** w wieku około 18–40 lat, średnio zaawansowani w obsłudze komputera, którzy cenią prywatność i chcą mieć pewność, że nikt poza nimi nie ma dostępu do ich notatek. Należą do niego m.in. studenci, programiści, freelancerzy, dziennikarze oraz osoby przechowujące w notatkach dane wrażliwe, takie jak hasła, dane medyczne czy dokumentacja.

Drugi segment to **małe zespoły i firmy** (mikro i małe przedsiębiorstwa, kancelarie, gabinety, agencje), które potrzebują bezpiecznego współdzielenia notatek, a nie dysponują własną infrastrukturą bezpieczeństwa ani zespołem specjalistów.

6.2. Model biznesowy

Model sprzedażowy opiera się na dwóch filarach. W **segmencie użytkowników indywidualnych** aplikacja będzie dostępna w modelu *freemium*. Wersja darmowa zapewni podstawowe funkcje z ograniczeniem liczby i wielkości notatek, a wersja *Premium* (abonament miesięczny lub roczny) zwiększy limity oraz doda współdzielenie notatek, kopie zapasowe i historię wersji.

W **segmencie instytucjonalnym** zostanie zaproponowana roczna licencja abonamentowa naliczana za użytkownika, z dodatkową opcją uruchomienia własnej instancji aplikacji (*self-hosting* w kontenerach Docker) wraz z płatnym wsparciem technicznym. Dla tego segmentu istotne jest to, że dane pozostają pod kontrolą klienta.

Ważnym elementem wartości produktu będzie **zaufanie do marki**. Aplikacja, której twórcy nie mają dostępu do treści notatek, buduje swoją pozycję na wiarygodności, dlatego rozważane jest udostępnienie rozwiązań kryptograficznych do niezależnego przeglądu.

6.3. Szacowana wielkość rynku

Poniższy szacunek ma charakter roboczy i opiera się na założeniach, które w kolejnych etapach należy zweryfikować badaniem rynku (ankietą oraz analizą konkurencji). Rynek jest konkurencyjny, ponieważ istnieją już aplikacje notatkowe i menedżery haseł z szyfrowaniem, dlatego realny udział przyjęto ostrożnie.

Segment	Założenia	Szacunek
Użytkownicy indywidualni	Ok. 10 mln internautów w wieku 18–40 lat w Polsce; ok. 5% zainteresowanych prywatnością i szyfrowaniem; udział produktu w pierwszych latach ok. 1%; ok. 3% użytkowników płacących	Ok. 500 tys. potencjalnych użytkowników; ok. 5 tys. aktywnych; ok. 150 płacących
Małe zespoły i firmy	Ok. 2 mln mikro i małych firm w Polsce; ok. 1% zainteresowanych; udział produktu ok. 2%	Ok. 20 tys. potencjalnych klientów; ok. 400 firm

7. Skład zespołu i role

Zespół liczy dwie osoby. Obowiązki kierownika projektu (koordynacja prac, pilnowanie terminów, prezentacja wyników) są dodatkiem do roli technicznej.

Rola	Zakres odpowiedzialności
Kierownik projektu + backend i bezpieczeństwo	Koordynacja zespołu i terminów, prezentacja; API w Django, przechowywanie zaszyfrowanych danych, uwierzytelnianie
Frontend i kryptografia	Interfejs użytkownika, szyfrowanie i odszyfrowywanie po stronie przeglądarki, wyprowadzanie klucza z hasła